Endpoint Security - Lab Exercises

> Exercise 1: Endpoint Hardening (45 min) | Exercise 2: OSSEC HIDS (60 min)

Table of Contents

- Exercise 1: Endpoint Hardening
  - Section 1: Hardening Windows 11
  - Section 2: Hardening Ubuntu
  - Section 3: Verification
- Exercise 2: OSSEC HIDS on Windows
  - Section 1: Install OSSEC Manager on Linux
  - Section 2: Install OSSEC Agent on Windows
  - Section 3: Register the Agent
  - Section 4: Configure Log Monitoring
  - Section 5: Generate and Respond to Alerts
  - Section 6: Analyze Alerts
  - Section 7: Configure Email Alerts (Optional)

Exercise 1: Endpoint Hardening

Duration: 45 minutes
Systems: Windows 11 and Ubuntu
Objective: Strengthen the security of both systems by applying encryption, disabling unnecessary services, and configuring firewalls.

Section 1: Hardening Windows 11

Task 1 - Enable BitLocker for Full Disk Encryption

Objective: Secure the system using full-disk encryption so that data is unreadable without the correct key, even if the drive is physically removed.

Steps:

1. Open the **Control Panel**
2. Navigate to **System and Security > BitLocker Drive Encryption**
3. Click **Turn on BitLocker** next to your primary drive (C:)
4. Follow the wizard to choose how to unlock the drive at startup and where to save your recovery key

Answer:

> Control Panel → System and Security → BitLocker Drive Encryption → Turn on BitLocker

Verification:

cmd

```
manage-bde -status
```

This command shows the encryption status of all drives. Confirm that the C: drive shows **Protection: On**.

Task 2 - Configure Windows Defender Exploit Guard

Objective: Protect the system from exploits and ransomware by enabling Controlled Folder Access, which prevents unauthorized applications from modifying protected folders.

Steps:

1. Open **Windows Security** (search for it in the Start menu)
2. Go to **Virus & threat protection**
3. Scroll down to **Ransomware protection** and click **Manage ransomware protection**
4. Toggle **Controlled Folder Access** to **On**

Answer:

> Windows Security → Virus & threat protection → Manage ransomware protection → Turn on Controlled Folder Access

Verification:

- Return to the Ransomware protection screen and confirm the toggle is enabled
- Optionally, add protected folders via **Protected folders** in the same menu

---

Task 3 - Disable Unnecessary Services

Objective: Minimize the attack surface by stopping and disabling services that are not needed. Every running service is a potential entry point for attackers.

Steps:

1. Press `Win + R`, type `services.msc`, and press Enter
2. Locate each of the following services:
   - **Remote Desktop Services** — not needed unless you use RDP
   - **Print Spooler** — not needed on machines that don't print
   - Any other services identified as unused in your environment
3. Right-click the service → **Properties**
4. Set **Startup type** to **Disabled**
5. Click **Stop** if the service is currently running
6. Click **OK**

Answer:

> Open `services.msc` → find the target service → Properties → set to Disabled → Stop

> ⚠️ Be cautious - disabling the wrong service can affect system functionality. Research each service before disabling it.

Task 4 - Enable UEFI Secure Boot

Objective: Protect against boot-level malware (bootkits and rootkits) that loads before the operating system, which traditional security software cannot detect.

Steps:

1. Restart the system
2. During boot, press the UEFI key - usually **F2**, **Del**, or **F10** (varies by manufacturer)
3. Navigate to the **Boot** or **Security** section in the UEFI menu
4. Find **Secure Boot** and set it to **Enabled**
5. Save changes and exit (usually **F10**)

Answer:

> Reboot → enter UEFI (F2/Del) → navigate to Secure Boot settings → Enable → Save and exit

> If the option is greyed out, the system may need to be in UEFI mode rather than Legacy/CSM mode. Ensure the OS was installed in UEFI mode first.

Section 2: Hardening Ubuntu

Task 1 - Install Unattended-Upgrades

Objective: Ensure the system automatically receives and installs security patches, closing known vulnerabilities without requiring manual intervention.

Steps:

Install the package:

bash

```
sudo apt install unattended-upgrades
```

Enable automatic upgrades by editing the configuration file:

bash

```
sudo nano /etc/apt/apt.conf.d/50unattended-upgrades
```

Ensure the following line is uncommented to enable security updates:

```
"${distro_id}:${distro_codename}-security";
```

To enable automatic execution, also edit:

bash

```
sudo nano /etc/apt/apt.conf.d/20auto-upgrades
```

And confirm these lines are present:

```
APT::Periodic::Update-Package-Lists "1";
APT::Periodic::Unattended-Upgrade "1";
```

Answer:

> `sudo apt install unattended-upgrades` → edit `/etc/apt/apt.conf.d/50unattended-upgrades`

Task 2 - Disable Unused Ports and Services

Objective: Reduce the attack surface by ensuring that no unnecessary network-facing services are running and no unnecessary ports are open.

Disable SSH (if not needed):

bash

```bash
sudo systemctl disable ssh
sudo systemctl stop ssh
```

Check which ports are currently open:

bash

```bash
sudo ufw status
```

Check all active listening ports:

bash

```bash
sudo ss -tulnp
```

Review the output and disable any service you don't need using:

bash

```bash
sudo systemctl disable <service-name>
sudo systemctl stop <service-name>
```

Answer:

> `sudo systemctl disable ssh` + `sudo ufw status` to verify only necessary ports are open

Task 3 - Enable AppArmor

Objective: Enforce mandatory access control policies on applications, limiting what resources each application can access - even if it is compromised.

Check AppArmor status:

bash

```bash
sudo apparmor_status
```

You should see profiles listed as **enforce** mode. If AppArmor is not active:

bash

```bash
sudo systemctl enable apparmor
sudo systemctl start apparmor
```

To view or modify a policy, navigate to the AppArmor profiles directory:

bash

```bash
ls /etc/apparmor.d/
```

Edit a specific profile (example for a custom service):

bash

```bash
sudo nano /etc/apparmor.d/usr.sbin.<your-service>
```

After editing a profile, reload it:

bash

```bash
sudo apparmor_parser -r /etc/apparmor.d/<profile-name>
```

Answer:

> `sudo apparmor_status` to check → edit profiles under `/etc/apparmor.d/` → reload with `apparmor_parser -r`

Task 4 - Configure a Firewall (UFW)

Objective: Protect the system by ensuring only explicitly permitted traffic can reach it, blocking all other inbound connections by default.

Enable UFW:

bash

```bash
sudo ufw enable
```

Allow only the services you need (examples):

bash

```bash
sudo ufw allow ssh        # if SSH is needed
sudo ufw allow 80/tcp     # HTTP
sudo ufw allow 443/tcp    # HTTPS
```

Deny everything else by default (UFW does this automatically when enabled).

Check the current rules:

bash

```bash
sudo ufw status verbose
```

To remove a rule you no longer need:

bash

```bash
sudo ufw delete allow <service>
```

Answer:

> `sudo ufw enable` → `sudo ufw allow <service>` for each required service → `sudo ufw status` to verify

Section 3: Conclusion and Verification

After completing all tasks, verify that each hardening step is active and correctly configured.

Windows 11 Verification

Task	Verification Command / Location
BitLocker	`manage-bde -status` in Command Prompt
Exploit Guard / Controlled Folder Access	Windows Security → Ransomware protection (toggle must show On)
Disabled services	`services.msc` — confirm target services show Disabled
Secure Boot	UEFI settings or run `msinfo32` → check Secure Boot State

Ubuntu Verification

Task	Verification Command
Unattended-Upgrades	`sudo systemctl status unattended-upgrades`
SSH disabled	`sudo systemctl status ssh` (should show inactive/disabled)
AppArmor active	`sudo apparmor_status` (profiles should show enforce mode)
UFW firewall rules	`sudo ufw status verbose`

Exercise 2: OSSEC HIDS on Windows

Duration: 60 minutes
Objective: Install, configure, and use OSSEC as a Host-based Intrusion Detection System (HIDS) to monitor a Windows machine, generate alerts, and analyze suspicious activity.

Architecture: OSSEC uses a **Manager/Agent** model. The **Manager** runs on Linux and collects and analyzes data. The **Agent** runs on Windows and forwards logs to the Manager.

Section 1: OSSEC Manager Installation on Linux

Before the Windows agent can be set up, an OSSEC Manager must be running on a Linux system to receive and process alerts.

Step 1 - Update the system:

On Ubuntu:

bash

```
sudo apt-get update
```

On CentOS:

bash

```
sudo yum update
```

Step 2 - Install required packages:

On Ubuntu:

bash

```
sudo apt-get install git build-essential
```

On CentOS:

bash

```
sudo yum install git gcc make
```

Step 3 - Clone the OSSEC repository and run the installer:

bash

```
git clone https://github.com/ossec/ossec-hids.git /tmp/ossec-hids
cd /tmp/ossec-hids
sudo ./install.sh
```

Step 4 - Choose installation type:

When prompted by the installer, select `server` as the installation type.

Follow the remaining prompts to complete the installation.

Section 2: OSSEC Agent Installation on Windows

With the Manager running, install the OSSEC agent on the Windows machine.

Step 1 - Download the agent:

- Go to the OSSEC Downloads page
- Download the latest **Windows agent** installer

Step 2 - Run the installer:

- Execute the downloaded `.exe` file
- When prompted for installation type, select **Agent**

Step 3 - Enter the Manager IP:

- During installation, enter the **IP address of your Linux OSSEC Manager**
- Ensure the Windows machine can reach the Manager over the network (check firewall rules on both sides)

Step 4 - Open the OSSEC Agent Manager:

- After installation, open **OSSEC Agent Manager** from the Start menu
- This is the GUI interface for managing the Windows agent

Section 3: Registering the Agent with the OSSEC Manager

The Manager must recognize and trust the Windows agent before it will accept data from it.

Step 1 - On the Linux Manager, run the agent manager tool:

bash

```
sudo /var/ossec/bin/manage_agents
```

Step 2 - Add the Windows agent:

- Press `A` to add a new agent
- Enter the **name** and **IP address** of the Windows machine
- Confirm to generate a registration key

Step 3 - Copy the key:

- After adding the agent, press `E` to extract the key
- Select the agent ID to display the key
- **Copy the entire key string**

Step 4 - Register the key on the Windows machine:

- Open the **OSSEC Agent Manager** on Windows
- Go to **Manage > Authentication key**
- Paste the key copied from the Manager
- Click **Save**

Step 5 - Restart the OSSEC agent service on Windows:

- In the OSSEC Agent Manager, click **Manage > Start OSSEC**
- Or from Command Prompt (as Administrator):

cmd

```
net start OssecSvc
```

Section 4: Configuring OSSEC for Log Monitoring on Windows

OSSEC can monitor Windows Event Logs. Configure it to watch the Security and System logs where important events (logins, privilege changes, policy changes) are recorded.

Step 1 - Open the OSSEC configuration file:

Navigate to:

```
C:\Program Files (x86)\ossec-agent\ossec.conf
```

Open it with a text editor (run as Administrator).

Step 2 - Add log monitoring entries:

Inside the `<ossec_config>` block, add:

xml

```xml
<localfile>
  <log_format>eventchannel</log_format>
  <location>Security</location>
</localfile>

<localfile>
  <log_format>eventchannel</log_format>
  <location>System</location>
</localfile>
```

Step 3 - Save and restart the agent:

cmd

```
net stop OssecSvc
net start OssecSvc
```

Section 5: Generating and Responding to OSSEC Alerts

To verify that OSSEC is working correctly, generate some suspicious activity that should trigger alerts.

Step 1 - On the Windows machine, open Command Prompt as Administrator and run:

cmd

```
net user testuser /add
net localgroup administrators testuser /add
```

These commands create a new user account and add it to the Administrators group — both are high-priority security events that OSSEC should detect.

Step 2 - On the Linux Manager, watch the alert log in real time:

bash

```
sudo tail -f /var/ossec/logs/alerts/alerts.log
```

You should see alerts appear shortly after running the commands on Windows. They will reference **user creation** and **privilege escalation** events.

Step 3 - Document the alert:

Note down the following from the alert output:

- Alert ID
- Timestamp
- Rule ID and description
- Source (Windows machine name/IP)

Section 6: Analyzing OSSEC Alerts

After generating alerts, analyze them to understand how OSSEC detects and classifies threats.

Step 1 - Open the full alert log on the Manager:

bash

```
sudo cat /var/ossec/logs/alerts/alerts.log
```

Step 2 - Identify the relevant alert from the Windows machine by looking for the events triggered in Section 5.

Step 3 - For each alert, analyze the following details:

Field	What to Look For
Alert ID	Unique identifier for the alert
Time of event	When the suspicious activity occurred
Rule ID	OSSEC rule that triggered (e.g., Rule 18101 for Windows user creation)
Description	Human-readable summary of the suspicious activity
Source	Hostname and IP of the Windows agent

Step 4 - Reflect on the following:

Why is monitoring user creation and privilege escalation important? In a real attack, an adversary who gains initial access will often create a backdoor account or escalate privileges to maintain persistence. OSSEC's ability to alert on these actions in real time enables rapid response before the attacker can entrench further.

Section 7: Configuring Email Alerts (Optional)

Configure OSSEC to send email notifications when alerts are generated, so the security team is notified even when they are not actively monitoring the log file.

Step 1 - On the Linux Manager, open the OSSEC configuration file:

bash

```bash
sudo nano /var/ossec/etc/ossec.conf
```

Step 2 - Add email settings inside the `<global>` section:

xml

```xml
<global>
  <email_notification>yes</email_notification>
  <smtp_server>your_smtp_server</smtp_server>
  <email_from>ossec-alerts@yourdomain.com</email_from>
  <email_to>your_email@domain.com</email_to>
  <email_level>7</email_level>
</global>
```

> `email_level` sets the minimum alert severity that triggers an email. Level 7 captures most meaningful security events. Adjust as needed.

Step 3 - Save and restart OSSEC on the Manager:

bash

```bash
sudo /var/ossec/bin/ossec-control restart
```

Step 4 - Verify email alerts:

Trigger another alert on the Windows machine (for example, another failed login attempt or user creation) and confirm that an email notification arrives at the configured address.

Summary

Exercise	System	Key Tasks
Hardening	Windows 11	BitLocker, Exploit Guard, Disable services, Secure Boot
Hardening	Ubuntu	Unattended-upgrades, Disable SSH, AppArmor, UFW
OSSEC HIDS	Linux (Manager)	Install OSSEC server, manage agents, monitor alerts
OSSEC HIDS	Windows (Agent)	Install agent, register with Manager, configure log monitoring
OSSEC HIDS	Both	Generate suspicious activity, analyze and document alerts

---